accessed or used without authorization.[1096] Given the computational complexity involved in deciphering information encrypted using modern encryption algorithms and secure procedures, [1097] the compromise of such encrypted information would generally not give rise to "a reasonably likely risk of substantial harm or inconvenience to an individual identified with the information."[1098] It would thus not constitute "sensitive customer information," meaning that the threshold for providing notice would not be met. In addition, when determining that the compromised sensitive customer information has not been, and is not reasonably likely to be, used in a manner that would result in substantial harm or inconvenience, a covered institution may consider encryption as a factor.[1099] Hence, in some cases, an explicit encryption safe harbor would be superfluous. In certain other cases, however, an explicit encryption safe harbor may not be as protective as the final amendments' Federal minimum standard for determining whether the compromise of customer information could create "a reasonably likely risk of substantial harm or inconvenience to an individual identified with the information."[1100] It may also become outdated as technologies and security practices evolve. Thus, while an explicit (and appropriately

---

1096 *See* final rule 248.30(a)(3)(iii).

1097 Here, "secure procedures" refers to the secure implementation of encryption algorithms and encompasses proper key generation and management, timely patching, user access controls, etc.

1098 *See* final rule 248.30(d)(9); *see also supra* footnotes 139 and 141 and accompanying text.

1099 *See* final rule 248.30(a)(4); *see also supra* footnote 138 and accompanying text.

1100 *See* final rule 248.30(d)(9). The Aug. 2022 breach of the LastPass cloud-based password manager provides an illustrative example. In this data breach a large database of website credentials belonging to LastPass customers was exfiltrated. The customer credentials in this database were encrypted using a secure algorithm and the encryption keys could not have been exfiltrated in the breach, so an encryption safe harbor could be expected to apply in such a case. Nonetheless, customers whose encrypted passwords were divulged in the breach became potential targets for brute force attacks (i.e., attempts to decrypt the passwords by guessing a customer's master password) and to phishing attacks (i.e., attempts to induce an affected customer to divulge the master password). *See* Karim Toubba, *Notice of Recent Security Incident*, LASTPASS (Dec. 22, 2022), *available at* https://blog.lastpass.com/2022/12/notice-of-recent-security-incident/; *see also* Craig Clough, *LastPass Security Breach Drained Bitcoin Wallet, User Says*, PORTFOLIO MEDIA (Jan. 4, 2023), *available at* https://www.law360.com/articles/1562534/lastpass-security-breach-drained-bitcoin-wallet-user-says.

circumscribed) safe harbor could provide some procedural efficiencies from streamlined application, it could also be misapplied.

4. Longer Customer Notification Deadlines

The Commission considered incorporating longer customer notification deadlines, such as 60 or 90 days instead of the adopted 30 days, as well as providing no fixed customer notification deadline. Several commenters suggested longer customer notification deadlines.[1101] Although longer notification deadlines would provide more time for covered institutions to rebut the presumption of notification discussed in section II.A.3.a, we expect that longer investigations would, in general, correlate with more serious or complicated incidents and would therefore be unlikely to end in a determination that sensitive customer information has not been and is not reasonably likely to be used in a manner that would result in substantial harm or inconvenience. We therefore do not expect that longer notification deadlines would ultimately lead to significantly fewer required notifications. Compliance costs conditional on notices being required (i.e., the actual furnishing of notices to customers) would be largely unchanged under alternative notice deadlines. That said, costs related to incident assessment would likely be somewhat lower due to the reduced urgency of determining the scope of an incident and a reduced likelihood that notifications would need to be made before an incident has been contained.[1102] Arguably, longer notification deadlines may increase reputational costs borne by covered institutions that choose to take advantage of the longer deadlines. Overall, however, we

---

[1101] *See, e.g.*, FSI Comment Letter; IAA Comment Letter 1. *See also supra* footnote 796 and accompanying text and *supra* section II.A.3.d(1) for a discussion of the comments received on this matter.

[1102] *See supra* section IV.D.1.b(2).

do not expect that longer notification deadlines would lead to costs for covered institutions that differ significantly from the costs of the adopted 30-day outside timeframe.

Providing for longer notifications deadlines would likely reduce the promptness with which some covered institutions issue notifications to customers, potentially reducing their customers' ability to take effective mitigating actions. In particular, as discussed in section IV.D.1.b(2), some breaches are discovered very quickly. For customers whose sensitive customer information is compromised in such breaches, a longer notification deadline could significantly reduce the timeliness—and value—of the notice.[1103] On the other hand, where a public announcement could hinder containment efforts, a longer notification timeframe could yield benefits to the broader public (and/or to the affected investors).[1104]

5. Broader National Security and Public Safety Delay in Customer Notification

The Commission considered providing for a broader delay to the 30-day notification outside timeframe by extending its applicability to cases where any appropriate law enforcement agency requests the delay.[1105] This alternative delay would more closely align with the delays adopted by other regulators, such as the Banking Agencies,[1106] and by many states.[1107] Several

---

1103 *See supra* footnote 784 and accompanying text.

1104 *See supra* footnote 803 and accompanying text.

1105 The final amendments differ from the proposal in that they allow for a longer national security and public safety delay under certain circumstances and allow for a delay if the notice poses a substantial risk to either public safety or national security (the proposal referred to national security risk only). However, the final amendments allow for such a delay only if the Attorney General informs the Commission, in writing, of such risk. *See supra* section II.A.3.d(2).

1106 *See* Banking Agencies' Incident Response Guidance.

1107 *See, e.g.*, RCW 19.255.010(8); Fla. Stat. § 501.171(4)(b).

commenters suggested broader delays.[1108] On the other hand, another commenter stated that the Commission should not allow for any law enforcement delay.[1109]

The principal function of a law enforcement delay is to allow a law enforcement or national security agency to prevent cybercriminals from becoming aware of their detection. Observing a cyberattack that is in progress can allow investigators to take actions that can assist in revealing the attacker's location, identity, or methods.[1110] Notifying affected customers has the potential to alert attackers that their intrusion has been detected, hindering these efforts.[1111] Thus, a broader delay could generally be expected to enhance law enforcement's efficacy in cybercrime investigations, which would potentially benefit affected customers through damage mitigation and benefit the general public through improved deterrence and increased recoveries, and by enhancing law enforcement's knowledge of attackers' methods. It would also potentially reduce compliance costs for covered institutions by aligning more closely with the existing regulations discussed above.[1112]

That said, use of the delay provisions would necessarily result in customers affected by a cyberattack being notified later, reducing the value to customers of such notices.[1113] Incidents where law enforcement would like to delay customer notifications are likely to involve numerous customers, who—without timely notice—may be unable to take timely mitigating actions that

---

1108 *See, e.g.*, Nasdaq Comment Letter; ICI Comment Letter 1.

1109 *See* Better Markets Comment Letter.

1110 *Cybersecurity Advisory: Technical Approaches to Uncovering and Remediating Malicious Activity*, CYBERSECURITY & INFRASTRUCTURE SEC. AGENCY (Sept. 24, 2020), *available at* https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-245a (explaining how and why investigators may "avoid tipping off the adversary that their presence in the network has been discovered").

1111 *Id*.

1112 *See supra* section IV.C.2.

1113 *See supra* footnote 784 and accompanying text.

could prevent additional harm.[1114] Law enforcement investigations can also take time to resolve and, even when successful, their benefits to affected customers (e.g., recovery of criminals' ill-gotten gains) may be limited.

Information about cybercrime investigations is often confidential. The Commission does not have data on the prevalence of covert cybercrime investigations, their success or lack of success, their deterrent effect if any, or the impact of customer notification on investigations.[1115] No commenter suggested such data. Thus, we are unable to quantify the costs and benefits of this alternative.[1116]

V. PAPERWORK REDUCTION ACT

A. Introduction

Certain provisions of the final amendments contain "collection of information" requirements within the meaning of the Paperwork Reduction Act of 1995 ("PRA").[1117] We are submitting the final collection of information to the Office of Management and Budget ("OMB") for review in accordance with the PRA.[1118] The safeguards rule and the disposal rule we are amending will have an effect on the currently approved existing collection of information under OMB Control No. 3235-0610, the title of which is, "Rule 248.30, Procedures to safeguard customer records and information; disposal of consumer report information."[1119] An agency may

---

1114 *See supra* section IV.D.1.b(2).

1115 We do, however, have evidence that requests by law enforcement to delay customer notification are relatively rare events. *See supra* footnote 806.

1116 We requested public comment on these topics in the Proposing Release but did not receive any.

1117 44 U.S.C. 3501 through 3521.

1118 44 U.S.C. 3507(d); 5 CFR 1320.11.

1119 The paperwork burden imposed by Regulation S-P's notice and opt-out requirements, 17 CFR 248.1 to 248.18, is currently approved under a separate OMB control number, OMB Control No. 3235-0537. The final amendments will implement a statutory exception that has been in effect since late 2015. We do not believe that the amendment to implement the statutory exception makes any substantive modifications to

not conduct or sponsor, and a person is not required to respond to, a collection of information unless it displays a currently valid OMB control number. The amended requirement to adopt policies and procedures constitutes a collection of information requirement under the PRA. The collection of information associated with the final amendments will be mandatory, and responses provided to the Commission in the context of its examination and oversight program concerning the final amendments will be kept confidential subject to the provisions of applicable law. A description of the final amendments, including the need for the information and its use, as well as a description of the types of respondents, can be found in section II above, and a discussion of the expected economic effects of the final amendments can be found in section III above. The Commission published notice soliciting comments on the collection of information requirements in the Proposing Release and submitted the proposed collections of information to OMB for review in accordance with 44 U.S.C. 3507(d) and 5 CFR 1320.11.

The Commission did not receive any comments that specifically addressed the estimated PRA analysis in the Proposing Release but did receive comments regarding the costs and burdens of the proposed rules generally. Those comments are discussed in more detail in section IV above. In particular, several commentators raised concerns regarding the costs associated with

---

this existing collection of information requirement or imposes any new substantive recordkeeping or information collection requirements within the meaning of the PRA. Similarly, we do not believe that the final amendments to: (i) Investment Company Act rules 31a-1(b) (OMB control number 3235-0178) and 31a-2(a) (OMB control number 3235-0179) for investment companies that are registered under the Investment Company Act, (ii) Investment Advisers Act rule 204-2 (OMB control number 3235-0278) for investment advisers, (iii) Exchange Act rule 17a-4 (OMB control number 3235-0279) for broker-dealers, and (iv) Exchange Act rule 17Ad-7 (OMB control number 3235-0291) for transfer agents, makes any modifications to this existing collection of information requirement or imposes any new recordkeeping or information collection requirements. Accordingly, we believe that the current burden and cost estimates for the existing collection of information requirements remain appropriate, and we believe that the final amendments should not impose substantive new burdens on the overall population of respondents or affect the current overall burden estimates for this collection of information. We are, therefore, not revising any burden and cost estimates in connection with these amendments.

negotiating and renegotiating written contracts with service providers.[1120] One commenter did support the proposed written contract provision due to its very narrow scope.[1121] In response to commenters' concerns about the costs of negotiating contracts, we have replaced the proposed requirement for a covered institution to have a written contract with a service provider with a requirement to implement written policies and procedures to oversee, monitor, and conduct due diligence on the service provider. In a modification from the proposal, rather than requiring written policies and procedures requiring the covered institution to enter into a written contract with its service providers to take certain appropriate measures, the policies and procedures required by the final amendments must be reasonably designed to ensure service providers take appropriate measures to: (A) protect against unauthorized access to or use of customer information; and (B) provide notification to the covered institution regarding an incident affecting customer information in the timeframes and circumstances discussed above. The modifications to the proposal are designed to address many of commenters' concerns regarding the costs associated with the service provider provisions of the proposed amendments. We have not reduced the Proposing Release's PRA estimates, however, because the final amendments still require policies and procedures regarding service providers that we estimate will involve PRA burdens consistent with those we estimated for the proposed requirement. As discussed above, some commenters urged for more time to investigate incidents, suggesting that failing to do so

---

1120 *See* STA and ComputerShares Comment Letters (transfer agents don't have the leverage to negotiate contracts with service providers); ASA Comment Letter (no discussion or estimate of the costs the written contract requirement would impose on brokers); IAA Comment Letter (individual advisers, particularly smaller advisers, lack leverage to engage in contractual negotiations with many service providers); ACLI Comment Letter; Cambridge Comment Letter; CAI Comment Letter; AWS Comment Letter; Google Comment Letter. Other commenters raised this issue but suggested extending the implementation period as a remedy. *See* NASDAQ Comment Letter; FIF Comment Letter; SIFMA Comment Letter 2.

1121 *See* ICI Comment Letter.

would result in an increase in the amount of notices being provided.[1122] We are increasing the estimates associated with the final rule with regards to the preparation and distribution of notices because these comments seem to suggest a view that the proposed estimates related to these burdens were too low. We have also adjusted the proposal's estimated annual burden hours and total time costs to reflect updated wage rates.

B. Amendments to the Safeguards Rule and Disposal Rule

As discussed above, the final amendments to the safeguards rule will require covered institutions to develop, implement, and maintain written policies and procedures that include incident response programs reasonably designed to detect, respond to, and recover from unauthorized access to or use of customer information, including customer notification procedures. The response program must include procedures to assess the nature and scope of any incident involving unauthorized access to or use of customer information; take appropriate steps to contain and control the incident; and provide notice to each affected individual whose sensitive customer information was, or is reasonably likely to have been, accessed or used without authorization (unless the covered institution makes certain determinations as specified in the final amendments).

The final amendments to the disposal rule will require covered institutions that maintain or otherwise possess customer information, or consumer information to adopt and implement written policies and procedures that address proper disposal of such information, which will include taking reasonable measures to protect against unauthorized access to or use of the information in connection with its disposal.

[1122] *See, e.g.*, *supra* footnote 165 and accompanying text.

Finally, the final amendments will require covered institutions other than funding portals to make and maintain written records documenting compliance with the requirements of the safeguards rule and the disposal rule. Under the final amendments, the time periods for preserving records will vary by covered institution to be consistent with existing recordkeeping rules.[1123]

Based on FOCUS Filing, Form BD Filing, and Form BD-N data, as of the third quarter of 2023, there were 3,476 brokers or dealers, other than notice-registered brokers or dealers or funding portals. Based on Investment Adviser Registration Depository data, as of Oct. 5, 2023, there were 15,565 investment advisers registered with the Commission. As of Sept. 30, 2023, there were 13,766 investment companies.[1124] Based on Form TA-1, as of Sept. 30, 2023, there were 251 transfer agents registered with the Commission and 64 transfer agents registered with the Banking Agencies. Based on staff analysis and publicly available filings, as of Dec. 31, 2023, there were 92 funding portals.

Table 5 below summarizes our PRA initial and ongoing annual burden estimates associated with the final amendments to the safeguards rule and the disposal rule.

Table 5: Amendments to Safeguards Rule and Disposal Rule - PRA

	Internal initial burden hours	Internal annual burden hours[1]	Wage rate[2]	Internal time cost	Annual external cost burden

[1123] The final amendments will also broaden the scope of information covered by the safeguards rule and the disposal rule (to include *all* customer information in the possession of a covered institution or is handled or maintained on its behalf, and all consumer information that a covered institution maintains or otherwise possesses for a business purpose) and extend the application of the safeguards provisions to transfer agents registered with the Commission or another appropriate regulatory agency. These amendments do not contain collections of information beyond those related to the incident response program analyzed above.

[1124] Data on investment companies registered with the Commission comes from Form N-CEN filings; data on BDCs comes from LSEG BDC Collateral; and data on employees' securities companies comes from Form 40-APP. *See supra* Table 4.

PROPOSED ESTIMATES					
Adopting and implementing policies and procedures	60 hours	25 hours[3]	$455 (blended rate for compliance attorney and assistant general counsel)	$11,375 (equal to the internal annual burden X the wage rate)	$2,655[4]
Preparation and distribution of notices	9 hours	8 hours[5]	$300 (blended rate for senior compliance examiner and compliance manager)	$2,400 (equal to the internal annual burden X the wage rate)	$2,018[6]
Recordkeeping	1 hour	1 hour	$381 (blended rate for compliance attorney and senior programmer)	$381	$0
Total new annual burden per covered institution		34 hours (equal to the sum of the above three boxes)		$14,156 (equal to the sum of the above three boxes)	$4,673 (equal to the sum of the above two boxes)
Number of covered institutions		x 32,897 covered institutions[7]		x 32,897 covered institutions	16,449[8]
Total new annual aggregate burden		1,118,498 hours		$465,689,932	$76,866,177
FINAL ESTIMATES					
Broker-dealers other than notice registered broker-dealers, investment advisers registered with the Commission and investment companies					
Adopting and implementing policies and procedures	60 hours	25 hours[3]	$501 (blended rate for compliance attorney and assistant general counsel)	$12,525 (equal to the internal annual burden X the wage rate)	$2,920[9]